

COMPLIANCE GAP ANALYSIS REPORT

GDPR Readiness Assessment — General Data Protection Regulation (EU) 2016/679

Company	TechStartup Pvt Ltd
Policy Analyzed	Privacy Policy v2.1 (August 2025)
Standard	GDPR — All 99 Articles, 11 Chapters
Analysis Date	6 August 2025
Generated By	ComplianceIQ Engine v1.0 — onetab.ai
Analyzed By	Agentic RAG Pipeline (4-Agent System)



Fully Met	12
Partially Met	9
Not Met	7
Conflicting	2
Total Requirements	30

RISK LEVEL: MEDIUM RISK — Action recommended

Max fine exposure: €20M or 4% annual revenue

Chapter-by-Chapter Breakdown

Ch	Chapter Name	Articles	Score	Status
1	General Provisions	Art. 1–4	—	Not Assessed
2	Principles	Art. 5–11	53.85%	Needs Improvement
3	Rights of the Data Subject	Art. 12–23	65.0%	Needs Improvement
4	Controller and Processor	Art. 24–43	42.86%	High Risk
5	Third Country Transfers	Art. 44–49	—	Not Assessed
6	Supervisory Authorities	Art. 51–59	—	Not Assessed
7	Cooperation & Consistency	Art. 60–76	—	Not Assessed
8	Remedies, Liability & Penalties	Art. 77–84	—	Not Assessed
9	Special Situations	Art. 85–91	—	Not Assessed
10	Delegated Acts	Art. 92–93	—	Not Assessed
11	Final Provisions	Art. 94–99	—	Not Assessed

Detailed Gap Analysis

5.1.a.1 · Art. 5(1)(a)

Fully Met Confidence: High (0.96)

GDPR Requires:

Personal data must be processed lawfully, fairly, and transparently.

Your Policy:

We process personal information lawfully, fairly and transparently.

Fix Required:

No action required.

5.1.b.1 · Art. 5(1)(b)

Fully Met Confidence: High (0.94)

GDPR Requires:

Data must be collected for specified, explicit, legitimate purposes and not further processed incompatibly.

Your Policy:

Personal information is collected for specified business purposes and is not used for unrelated purposes without appropriate authorization.

Fix Required:

No action required.

5.1.c.1 · Art. 5(1)(c)

Partially Met Confidence: High (0.91)

GDPR Requires:

Data collected must be adequate, relevant, and limited to what is necessary (data minimisation).

Your Policy:

We collect only information that is necessary to provide our services.

Fix Required:

No objective criteria or documented process for determining data necessity are provided.

5.1.d.1 · Art. 5(1)(d)

Not Met Confidence: High (0.88)

GDPR Requires:

Personal data must be accurate and kept up to date.

Your Policy:

No matching evidence found in policy.

Fix Required:

No mechanism for maintaining the accuracy of personal data is specified.

5.1.e.1 · Art. 5(1)(e)

Partially Met Confidence: High (0.91)

GDPR Requires:

Data must be kept in identifiable form no longer than necessary (storage limitation).

Your Policy:

Personal information is retained for as long as necessary to fulfill the purposes for which it was collected.

Fix Required:

A specific retention period or objective retention criteria are not provided.

5.1.f.1 · Art. 5(1)(f)

Fully Met Confidence: High (0.95)

GDPR Requires:

Data must be processed with appropriate security, integrity and confidentiality.

Your Policy:

We implement appropriate technical and organizational safeguards to protect personal information.

Fix Required:

No action required.

6.1.a.1 · Art. 6(1)(a)

Fully Met Confidence: High (0.93)

GDPR Requires:

Processing requires a valid legal basis, e.g. freely given consent.

Your Policy:

Where required, we obtain consent before processing personal information.

Fix Required:

No action required.

6.1.b.1 · Art. 6(1)(b)

Partially Met Confidence: High (0.89)

GDPR Requires:

Processing may be based on necessity for performance of a contract.

Your Policy:

Certain information may be processed when necessary to perform our contractual obligations.

Fix Required:

The legal basis is mentioned but not mapped to specific processing activities.

6.1.c.1 · Art. 6(1)(c)

Not Met Confidence: High (0.86)

GDPR Requires:

Processing may be based on compliance with a legal obligation.

Your Policy:

No matching evidence found in policy.

Fix Required:

No provision addressing processing based on legal obligations was identified.

7.1.1 · Art. 7(1)

Fully Met Confidence: High (0.97)

GDPR Requires:

Consent requests must be clearly distinguishable, intelligible and easily accessible.

Your Policy:

Consent requests are presented separately from other terms and may be withdrawn at any time.

Fix Required:

No action required.

7.1.2 · Art. 7(3)

Partially Met Confidence: High (0.9)

GDPR Requires:

Data subject must be able to withdraw consent at any time, as easily as it was given.

Your Policy:

Users may withdraw consent by contacting our privacy team.

Fix Required:

The policy does not explicitly establish equivalent ease between giving and withdrawing consent.

8.1.1 · Art. 8(1)

Not Met Confidence: High (0.84)

GDPR Requires:

Where a child's consent applies, verifiable parental/guardian authorization is required.

Your Policy:

No matching evidence found in policy.

Fix Required:

No mechanism for obtaining or verifying parental authorization is specified.

9.1.1 · Art. 9(1)

Conflicting Confidence: High (0.87)

GDPR Requires:

Processing of special categories of personal data (health, biometric, etc.) is prohibited unless an exemption applies.

Your Policy:

We do not intentionally collect sensitive personal information.

Fix Required:

The policy contains contradictory statements regarding the collection of special categories of personal data.

12.1.1 · Art. 12(1)

Fully Met Confidence: High (0.95)

GDPR Requires:

Information must be provided in a concise, transparent, intelligible, and easily accessible form, using plain language.

Your Policy:

This policy is written in clear and accessible language.

Fix Required:

No action required.

13.1.a.1 · Art. 13(1)(a)

Fully Met Confidence: High (0.96)

GDPR Requires:

The identity and contact details of the controller must be provided.

Your Policy:

ABC Ltd. is the controller responsible for your personal information. Our contact details are provided below.

Fix Required:

No action required.

13.1.c.1 · Art. 13(1)(c)

Partially Met Confidence: High (0.92)

GDPR Requires:

The purposes and legal basis of processing must be disclosed for each purpose.

Your Policy:

We use personal information to provide services, communicate with customers, and improve our products.

Fix Required:

The legal basis is not clearly mapped to each processing purpose.

14.1.1 · Art. 14(1)

Not Met Confidence: High (0.83)

GDPR Requires:

Where data is not obtained from the subject, equivalent transparency information must be provided.

Your Policy:

No matching evidence found in policy.

Fix Required:

No third-party data notification process is described.

15.1.1 · Art. 15(1)

Fully Met Confidence: High (0.94)

GDPR Requires:

Data subject has the right to obtain confirmation and access to their personal data.

Your Policy:

You may request access to the personal information we hold about you by submitting a request to our privacy team.

Fix Required:

No action required.

16.1.1 · Art. 16

Fully Met Confidence: High (0.94)

GDPR Requires:

Data subject has the right to rectification of inaccurate personal data.

Your Policy:

You may request correction of inaccurate or incomplete personal information.

Fix Required:

No action required.

17.1.1 · Art. 17(1)

Partially Met Confidence: High (0.93)

GDPR Requires:

Data subject has the right to erasure ('right to be forgotten') without undue delay.

Your Policy:

You may request deletion of your account and associated personal information.

Fix Required:

The policy does not clearly describe the applicable exceptions and conditions for erasure.

18.1.1 · Art. 18(1)**Not Met** Confidence: High (0.89)**GDPR Requires:**

Data subject has the right to obtain restriction of processing in specified circumstances.

Your Policy:

No matching evidence found in policy.

Fix Required:

The policy does not address restriction of processing.

20.1.1 · Art. 20(1)**Partially Met** Confidence: High (0.88)**GDPR Requires:**

Data subject has the right to receive their data in a structured, machine-readable format (portability).

Your Policy:

Users may request a copy of the personal information associated with their account.

Fix Required:

Data portability format and transmission requirements are not specified.

21.1.1 · Art. 21(1)**Fully Met** Confidence: High (0.93)**GDPR Requires:**

Data subject has the right to object to processing based on legitimate interests, at any time.

Your Policy:

You may object to certain uses of your personal information by contacting our privacy team.

Fix Required:

No action required.

22.1.1 · Art. 22(1)**Conflicting** Confidence: High (0.86)**GDPR Requires:**

Data subject has the right not to be subject to a decision based solely on automated processing.

Your Policy:

We do not make decisions about individuals solely through automated means.

Fix Required:

The policy contains inconsistent statements regarding automated decision-making.

25.1.1 · Art. 25(1)**Partially Met** Confidence: High (0.9)**GDPR Requires:**

Controller must implement data protection by design and by default.

Your Policy:

Privacy and security considerations are taken into account when developing new systems.

Fix Required:

No documented process or controls for embedding data protection into system design are specified.

30.1.1 · Art. 30(1)**Not Met** Confidence: High (0.85)**GDPR Requires:**

Controller must maintain a record of processing activities.

Your Policy:

No matching evidence found in policy.

Fix Required:

No record-of-processing-activities process or documentation is described.

32.1.1 · Art. 32(1)**Fully Met** Confidence: High (0.97)**GDPR Requires:**

Controller must implement appropriate technical/organizational security measures.

Your Policy:

Personal information is protected using encryption, access controls, monitoring and other appropriate security measures.

Fix Required:

No action required.

33.1.1 · Art. 33(1)**Partially Met** Confidence: High (0.92)**GDPR Requires:**

A personal data breach must be notified to the supervisory authority within 72 hours.

Your Policy:

Personal data breaches must be reported to the privacy team promptly for assessment and response.

Fix Required:

The policy does not explicitly state the applicable supervisory authority notification deadline.

35.1.1 · Art. 35(1)**Fully Met** Confidence: High (0.94)**GDPR Requires:**

A Data Protection Impact Assessment (DPIA) is required for high-risk processing.

Your Policy:

High-risk processing activities undergo a privacy impact assessment before implementation.

Fix Required:

No action required.

36.1.1 · Art. 36(1)**Not Met** Confidence: High (0.82)**GDPR Requires:**

Prior consultation with the supervisory authority is required where a DPIA indicates high residual risk.

Your Policy:

No matching evidence found in policy.

Fix Required:

No prior consultation procedure is specified.

Priority Action Plan

P1 — CRITICAL PRIORITY · 9 items

#	Sub-ID	GDPR Article	Action Required	Current Status
1	5.1.d.1	Art. 5(1)(d)	No mechanism for maintaining the accuracy of personal data is specified.	Not Met
2	6.1.c.1	Art. 6(1)(c)	No provision addressing processing based on legal obligations was identified.	Not Met
3	8.1.1	Art. 8(1)	No mechanism for obtaining or verifying parental authorization is specified.	Not Met
4	9.1.1	Art. 9(1)	The policy contains contradictory statements regarding the collection of special categories of personal data.	Conflicting
5	14.1.1	Art. 14(1)	No third-party data notification process is described.	Not Met
6	18.1.1	Art. 18(1)	The policy does not address restriction of processing.	Not Met
7	22.1.1	Art. 22(1)	The policy contains inconsistent statements regarding automated decision-making.	Conflicting
8	30.1.1	Art. 30(1)	No record-of-processing-activities process or documentation is described.	Not Met
9	36.1.1	Art. 36(1)	No prior consultation procedure is specified.	Not Met

P2 — HIGH PRIORITY · 9 items

#	Sub-ID	GDPR Article	Action Required	Current Status
1	5.1.c.1	Art. 5(1)(c)	No objective criteria or documented process for determining data necessity are provided.	Partially Met
2	5.1.e.1	Art. 5(1)(e)	A specific retention period or objective retention criteria are not provided.	Partially Met
3	6.1.b.1	Art. 6(1)(b)	The legal basis is mentioned but not mapped to specific processing activities.	Partially Met
4	7.1.2	Art. 7(3)	The policy does not explicitly establish equivalent ease between giving and withdrawing consent.	Partially Met
5	13.1.c.1	Art. 13(1)(c)	The legal basis is not clearly mapped to each processing purpose.	Partially Met
6	17.1.1	Art. 17(1)	The policy does not clearly describe the applicable exceptions and conditions for erasure.	Partially Met
7	20.1.1	Art. 20(1)	Data portability format and transmission requirements are not specified.	Partially Met
8	25.1.1	Art. 25(1)	No documented process or controls for embedding data protection into system design are specified.	Partially Met
9	33.1.1	Art. 33(1)	The policy does not explicitly state the applicable supervisory authority notification deadline.	Partially Met

Executive Summary

Executive summary pending — generated in Track B (LLM stage).

DISCLAIMER: This report was generated by ComplianceIQ, an AI-powered compliance analysis tool developed by onetab.ai. It is intended for informational purposes only and does not constitute legal advice. ComplianceIQ uses Agentic RAG technology to map policy text against regulatory requirements and may not capture all nuances of legal interpretation. Organizations should consult qualified legal counsel before making compliance decisions. Confidence scores indicate retrieval quality, not legal certainty.